

CAPSTONE PROJECT

BRUTE-FORCE ATTACK & ACCOUNT LOCKOUT RESPONSE

P R E S E N T A T I O N

VAISHALI PAWAR

28802



AGENDA

1. Introduction

- Objective, Overview & Scope of the Project

1. Environment Setup

- Windows 10 VM & Kali Linux

1. Attack Simulation

- Failed & Successful Login Attempts

1. Log Analysis

- Event Viewer Navigation
- Key Event IDs (4625 & 4624)
- Pattern Observation

1. Incident Response Plan

- Identifying Suspicious Behavior
- Basic Response Actions

1. Mitigation Measures

- Account Lockout Policies
- Strong Passwords & MFA

1. Root Cause Analysis (RCA)

- Summary of Findings
- Importance of Monitoring

1. Recommendations & Conclusion

- Security Best Practices
- Key Takeaway



1: OBJECTIVE, OVERVIEW & SCOPE OF THE PROJECT

- Objective

To simulate and analyze login anomalies on a Windows 10 system using Event Viewer, with the aim of detecting suspicious authentication activity and understanding the importance of log analysis in incident response.

- Overview

This project simulates failed and successful login attempts on a Windows 10 system and analyzes Event Viewer logs to detect suspicious login patterns. It highlights the role of log analysis in identifying security threats and supporting incident response.



1: OBJECTIVE, OVERVIEW & SCOPE OF THE PROJECT

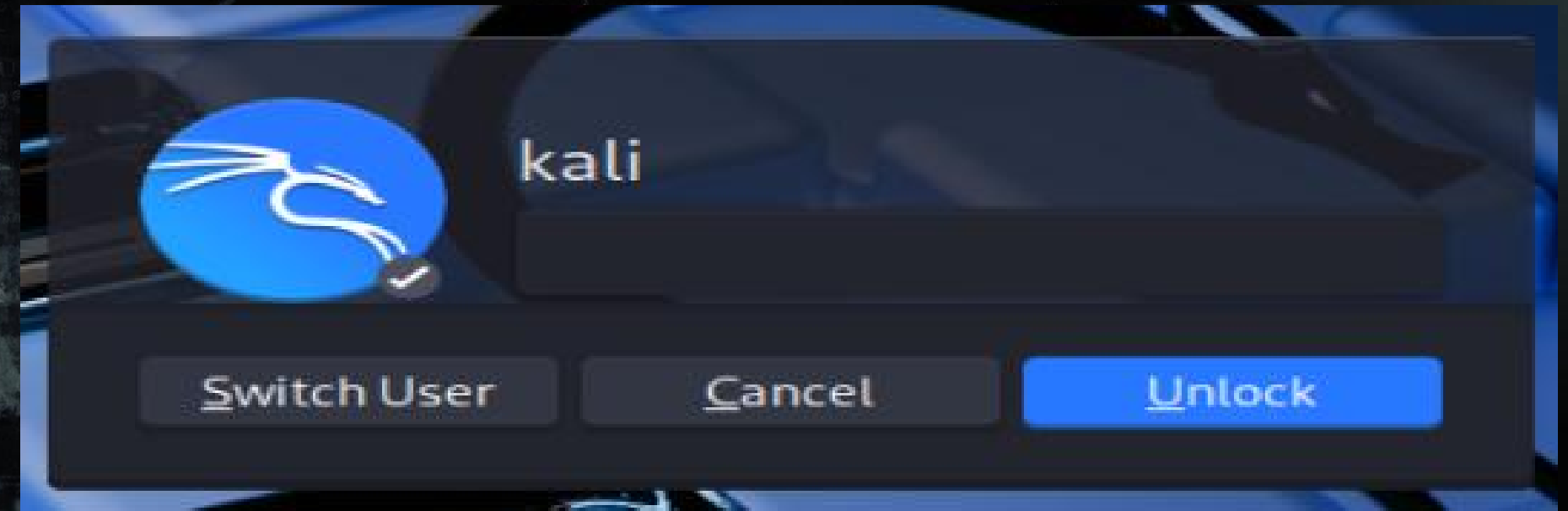
- Scope

1. Simulate multiple failed and one successful login on a Windows 10 virtual machine.
2. Identify and analyze relevant security events (Event ID 4625 – failed login, 4624 – successful login).
3. Demonstrate how log analysis supports incident detection and response.
4. Apply basic incident response planning based on observed login patterns.
5. Recommend security measures such as account lockout policies, strong passwords, and multi-factor authentication.



2: ENVIRONMENT SETUP

- Kali Linux VM (Attacker Machine)
- Windows 10/Server VM (Target Machine)
- Both VMs connected to the same network (NAT or Host-only)
- RDP enabled on Windows machine
- Firewall temporarily disabled on Windows for testing
- Required tools pre-installed:
 - Hydra on Kali Linux
 - rockyou.txt wordlist
- Event Viewer accessible on Windows for log monitoring



3: ATTACK SIMULATION

- Steps:

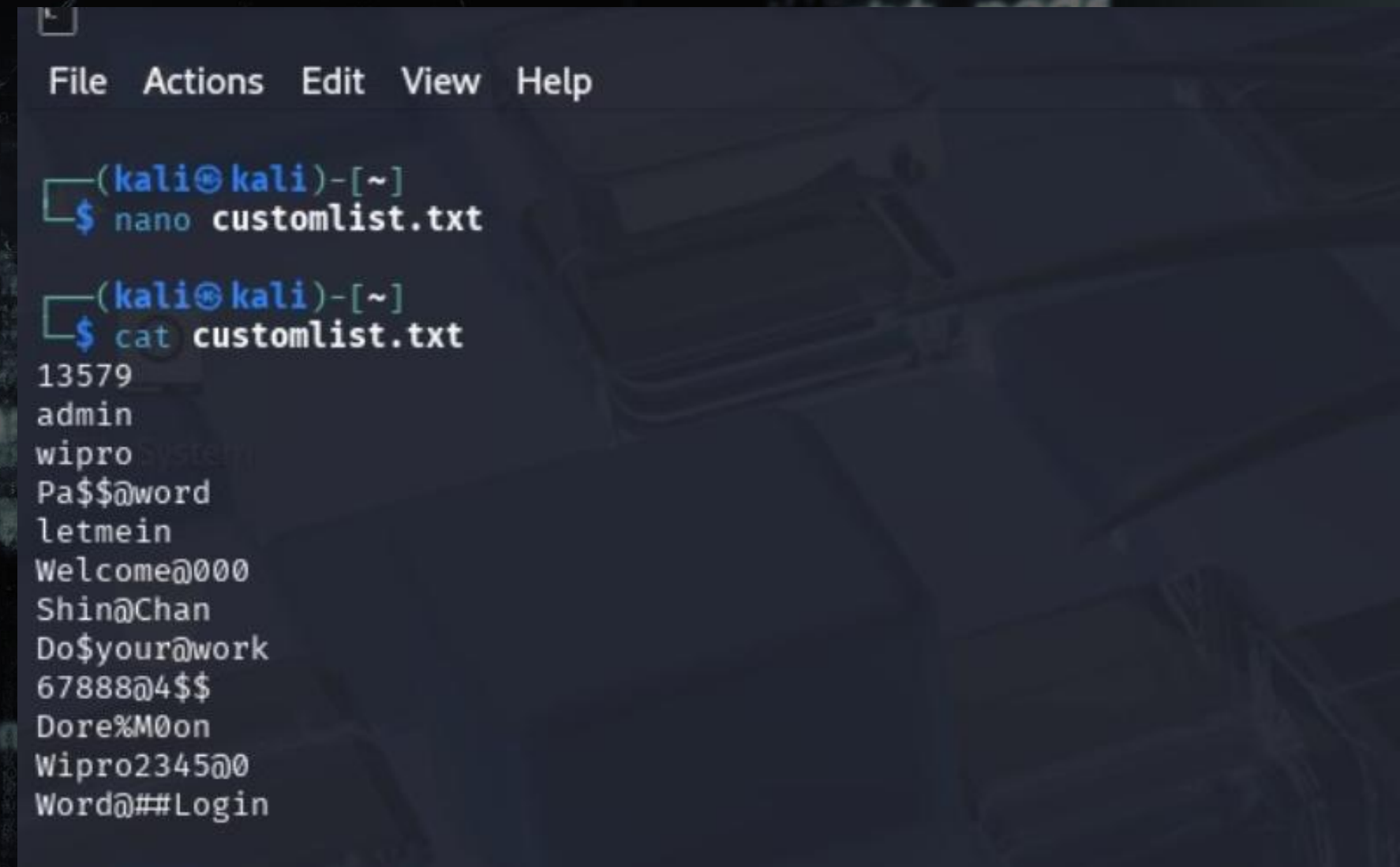
1. Preparation on Kali Linux (Attacker):

- Open Terminal and navigate to the directory containing rockyou.txt
- Ensure Hydra is installed:
 - sudo apt install hydra
- Locate or unzip the password file:
 - sudo gzip -d /usr/share/wordlists/rockyou.txt.gz

2. Preparation on Windows (Target):

- Enable Remote Desktop (RDP)
- Temporarily disable Windows Firewall
- Note the IP address using:
 - ipconfig

3. Executing the Brute-force Attack from Kali:



```
File Actions Edit View Help

(kali@kali)-[~]
$ nano customlist.txt

(kali@kali)-[~]
$ cat customlist.txt
13579
admin
wipro
Pa$$@word
letmein
Welcome@000
Shin@Chan
Do$your@work
67888@4$$
Dore%M@on
Wipro2345@0
Word@##Login
```



3: ATTACK SIMULATION

3.Executing the Brute-force Attack from Kali:

- Run Hydra with the following command:

hydra -l Administrator -P /usr/share/wordlists/rockyou.txt rdp://<target-IP>

(Replace <target-IP> with the actual IP address of the Windows machine)

```
—(kali@kali)-[~]
-$ hydra -v -l Administrator -p customlist.txt rdp://192.168.205.129
hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret serv

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-19 03:11:28
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of par
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[VERBOSE] More tasks defined than login/pass pairs exist. Tasks reduced to 1
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking rdp://192.168.205.129:3389/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[STATUS] attack finished for 192.168.205.129 (waiting for children to complete tests)
of 1 target completed, 0 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-19 03:11:28
```

```
—(kali@kali)-[~]
```



3: ATTACK SIMULATION

- Steps:

4.Expected Behavior:

- Hydra will attempt multiple failed login attempts using the wordlist.
- If the correct password is found, a successful login will occur.

```
(kali@kali)~$ hydra -l Administrator -P rockyou.txt rdp://192.168.205.128
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization-binding, these *** ignore laws and ethics anyway).

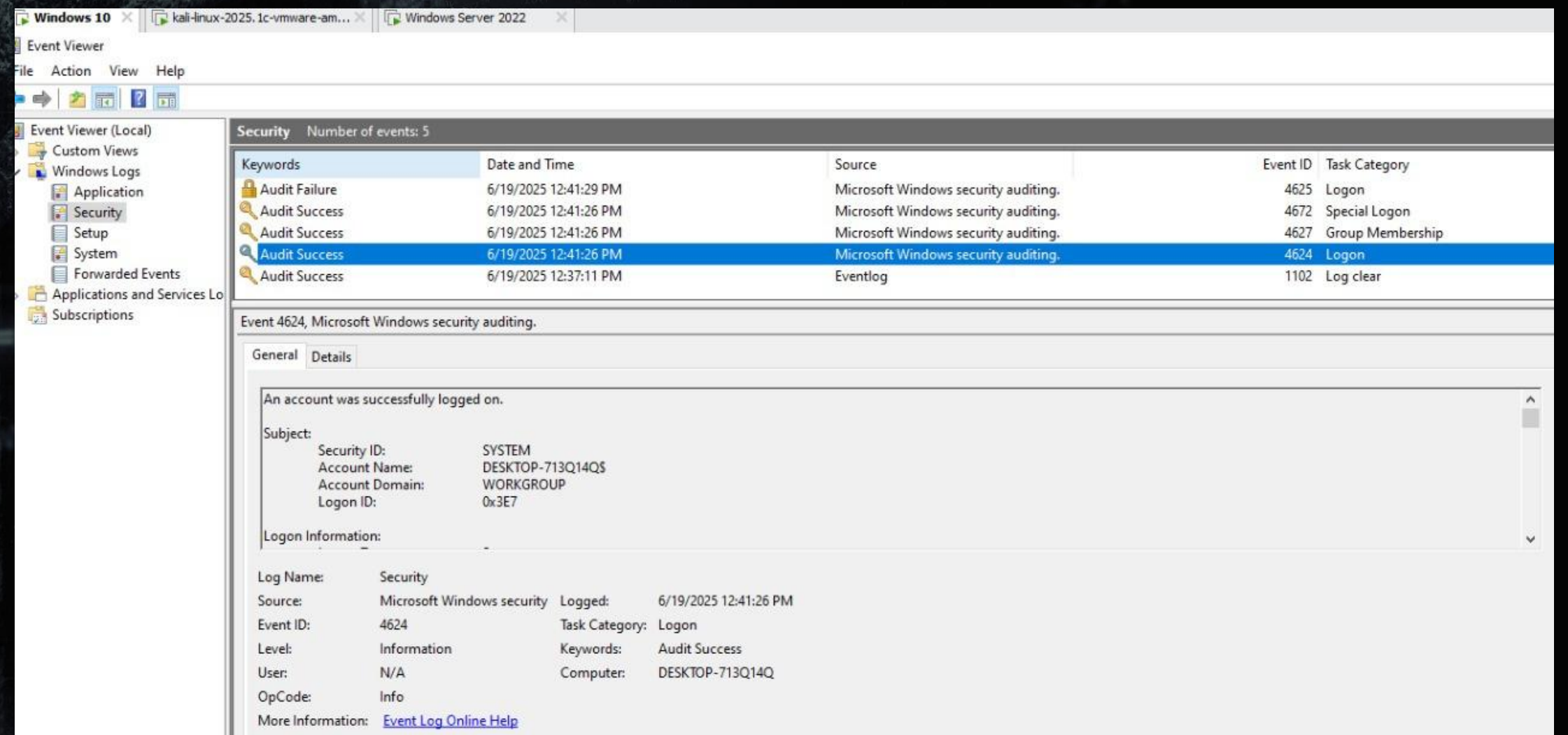
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-19 03:28:47
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of parallel connections to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 8 login tries (l:1/p:8), ~2 tries per task
[DATA] attacking rdp://192.168.205.128:3389/
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-19 03:29:20
```



3: ATTACK SIMULATION

5. Monitoring on Windows:

- Open Event Viewer
- Navigate to:
- Windows Logs → Security
- Filter and observe Event IDs:
 - 4625 – Failed Login
 - 4624 – Successful Login
- Analyze the pattern of failed attempts followed by a successful login.



4 : LOG ANALYSIS

1.Event Viewer Navigation

- Open Event Viewer on the Windows machine
- Go to:
 - Windows Logs → Security
- Use the Filter Current Log option to narrow down events
 - Filter by Event ID: 4625 (Failed Logon)
 - Filter by Event ID: 4624 (Successful Logon)

2.Key Event IDs

- 4625 – Failed Logon
 - Indicates an unsuccessful login attempt
 - Includes details like account name, failure reason, and source IP
- 4624 – Successful Logon
 - Represents a successful login event
 - Shows logon type, user name, and source machine

Filter Current Log

Filter XML

Logged: Last hour

Event level: ☐ Critical ☐ Warning ☐ Verbose ☐ Error ☐ Information

☒ By log Event logs: Security

☐ By source Event sources:

Includes/Excludes Event IDs: Enter ID numbers and/or ID ranges separated by commas. To exclude criteria, type a minus sign first. For example 1,3,5-99,-76

4625,4624

Task category:

Keywords:

User: <All Users>

Computer(s): <All Computers>

Clear

OK Cancel



4: LOG ANALYSIS

3. Pattern Observation

- Look for a sequence of multiple 4625 events followed by a single 4624
- This indicates a brute-force pattern: repeated failures followed by a successful login
- Analyze:
 - Time intervals between attempts
 - Logon types (e.g., Type 10 = Remote login)
 - Source IP address consistency

Security Number of events: 38,085 (!) New events available				
Filtered: Log: Security; Source: ; Event ID: 4625,4624 Date Range: Last hour. Number of events: 307				
Keywords	Date and Time	Source	Event ID	Task Category
 Audit Failure	6/18/2025 9:57:43 PM	Microsoft Windows security auditing.	4625	Logon
 Audit Failure	6/18/2025 9:57:40 PM	Microsoft Windows security auditing.	4625	Logon
 Audit Failure	6/18/2025 9:57:35 PM	Microsoft Windows security auditing.	4625	Logon
 Audit Success	6/18/2025 9:57:25 PM	Microsoft Windows security auditing.	4624	Logon



4 : LOG ANALYSIS

Security

Number of events: 38,085 (!) New events available

Filtered: Log: Security; Source: ; Event ID: 4625,4624

Date Range: Last hour. Number of events: 307

Keywords	Date and Time	Source	Event ID	Task Category
Audit Failure	6/18/2025 9:57:43 PM	Microsoft Windows security auditing.	4625	Logon
Audit Failure	6/18/2025 9:57:40 PM	Microsoft Windows security auditing.	4625	Logon
Audit Failure	6/18/2025 9:57:35 PM	Microsoft Windows security auditing.	4625	Logon
Audit Success	6/18/2025 9:57:25 PM	Microsoft Windows security auditing.	4624	Logon

Event 4625, Microsoft Windows security auditing.

Event 4625, Microsoft Windows security auditing.

General

Details

Account For Which Logon Failed:

Security ID: NULL SID

Account Name: Administrator

Account Domain: WIPRO

Failure Information:

Failure Reason: Unknown user name or bad password.

Status: 0xC000006D

Log Name: Security

Source: Microsoft Windows security

Event ID: 4625

Level: Information

User: N/A

OpCode: Info

More Information: [Event Log Online Help](#)

Logged: 6/18/2025 9:57:35 PM

Task Category: Logon

Keywords: Audit Failure

Computer: WIN-Q733BC9VA58.wipro.local

An account failed to log on.

Subject:

Security ID: SYSTEM

Account Name: WIN-Q733BC9VA58\$

Account Domain: WIPRO

Logon ID: 0x3E7



4: LOG ANALYSIS

Event 4625, Microsoft Windows security auditing.

General Details

Account For Which Logon Failed:

Security ID: NULL SID
Account Name: Administrator
Account Domain: WIPRO

Failure Information:

Failure Reason: Unknown user name or bad password.
Status: 0xC000006D

Log Name: Security
Source: Microsoft Windows security
Event ID: 4625
Level: Information
User: N/A
OpCode: Info
More Information: [Event Log Online Help](#)

Logged: 6/18/2025 9:57:35 PM
Task Category: Logon
Keywords: Audit Failure
Computer: WIN-Q733BC9VA58.wipro.local



4 : LOG ANALYSIS

Logon Failure – Status & SubStatus Common Login Failure Codes:

- **Status: 0xc000006d**
 - ◇ “Invalid logon: Bad username or authentication info”
- **SubStatus: 0xc000006a**
 - ◇ “Username correct but password is wrong”
- **SubStatus: 0xc0000064**
 - ◇ “Username does not exist”

Event 4625, Microsoft Windows security auditing.

General Details

☒ Friendly View ☐ XML View

SubjectDomainName WIPRO
SubjectLogonId 0x3e7
TargetUserSid S-1-0-0
TargetUserName Administrator
TargetDomainName WIPRO
Status 0xc000006d
FailureReason %%2313
SubStatus 0xc000006a
LogonType 2
LogonProcessName User32
AuthenticationPackageName Negotiate
WorkstationName WIN-Q733BC9VA58
TransmittedServices -

TargetDomainName WIPRO
Status 0xc000006d
FailureReason %%2313
SubStatus 0xc000006a
LogonType 2
LogonProcessName User32

4 : LOG ANALYSIS

Logon Types

Logon Type Codes:

2 → This means interactive logon — the attempt was made locally (physical or console login), not remotely.

3 → Network:

Indicates a network logon, which occurs when a user accesses a system remotely over the network — without physically logging

10 → Remote Desktop:

RDP session logon

📌 Note:

IP address appears only in types 3 or 10, not in type 2.

```
FailureReason    %%2313
SubStatus        0xc000006a
LogonType         2
LogonProcessName User32
AuthenticationPackageName Negotiate
```

```
LogonType        3
LogonProcessName Kerberos
AuthenticationPackageName Kerberos
WorkstationName -
LogonGuid         {75611ee5-0770-4f71-0304-1249369552bc}
TransmittedServices -
LmPackageName -
KeyLength         0
ProcessId         0x0
ProcessName       -
IpAddress         fe80::3ead:cb84:96d4:803a
IpPort            51891
```

5:INCIDENT RESPONSE PLAN

1.Identifying Suspicious Behavior

- Analyze Event Viewer logs for patterns like:
 - Multiple failed login attempts (Event ID 4625) within a short timeframe
 - Followed by a successful login (Event ID 4624) from the same IP
 - Logon Type 10 (indicates Remote Desktop access) can be a strong sign of external attack
- These behaviors suggest a possible brute-force attack or unauthorized access attempt



5:INCIDENT RESPONSE PLAN

2.Basic Response Actions

- Isolate the Affected System
 - Disconnect it from the network to prevent further access
- Reset Passwords
 - Immediately change passwords for compromised accounts
- Review User Privileges
 - Ensure no unauthorized elevation of access has occurred
- Check for Persistence
 - Look for suspicious scheduled tasks or services
- Document Everything
 - Time, source IP, user affected, logs—critical for RCA & reporting



5:INCIDENT RESPONSE PLAN

3.Playbook (To Follow Next)

- A step-by-step guide that defines the procedures for detecting, analyzing, and mitigating brute-force login attempts using Event Viewer logs.
- Link of the playbook -

<https://board.flexibleir.com/b/yNk68z7vLX6saAZvD/login-anomaly-detection>

Login anomaly detection Log In Filter Search Lists					
Playbook Details	Preparation	Detection	Incidence Response	Mitigation	Policy
 Prepared By : Soumya Vaishali Jagruthi Jatin Dewansh Mentor: Tapan sir Project date:19-06-2025	Ensure audit logon events are enabled in Group Policy GPO Path: Security Settings > Local Policies > Audit Policy > Audit logon events Confirm Security logs are collected in Event Viewer Know your key Event IDs: 4625 – Failed login 4624 – Successful login 0/2	Simulate attack Attempt 5–10 failed logins → then 1 successful login Open Event Viewer Windows Logs → Security  Filter Logs by Event ID Filter for: 4625, 4624 1 Analyze Fields in Each Log: Account Name Logon Type Source IP Address Failure Reason Detect Anomaly Look for: High number of 4625 followed by a	Containment: Temporarily disable the user account Block the suspicious IP Inform the security team Investigation: Check other logs (System, Application, Antivirus) Confirm if unauthorized access occurred Eradication: Scan the VM for malware Remove suspicious users or tasks Recovery: Reset the user's password Re-enable the account if safe Monitor for repeated login attempts	Objective: Prevent recurrence of similar login attacks. Configure Account Lockout Policy: Lock account after 5 invalid attempts for 15 minutes Enforce Strong Password Policies: Minimum 8–12 characters, complexity enabled Implement Multi-Factor Authentication (MFA): Add a second verification step during login Security Awareness Training: Educate users on secure login practices and phishing	Regular monitoring of logs is required. Multiple failed attempts from a single source within a short time frame trigger an alert to the system administrator  Frequency: Daily log review, automated alerts 1 Tools: Use SIEM or PowerShell scripting to automate



6:MITIGATION MEASURES

1.Account Lockout Policies

- Configure policies to temporarily lock user accounts after a set number of failed login attempts (e.g., 3–5)
- Helps prevent brute-force attacks by slowing down repeated login attempts
- Recommended settings:
 - Lockout threshold: 5 invalid attempts
 - Lockout duration: 15–30 minutes
 - Reset counter after: 15 minutes

2.Strong Passwords

- Enforce password complexity:
 - Minimum length (8–12 characters)
 - Combination of uppercase, lowercase, numbers, and symbols
- Avoid using common or dictionary-based passwords
- Encourage periodic password updates



6:MITIGATION MEASURES

3.Multi-Factor Authentication (MFA)

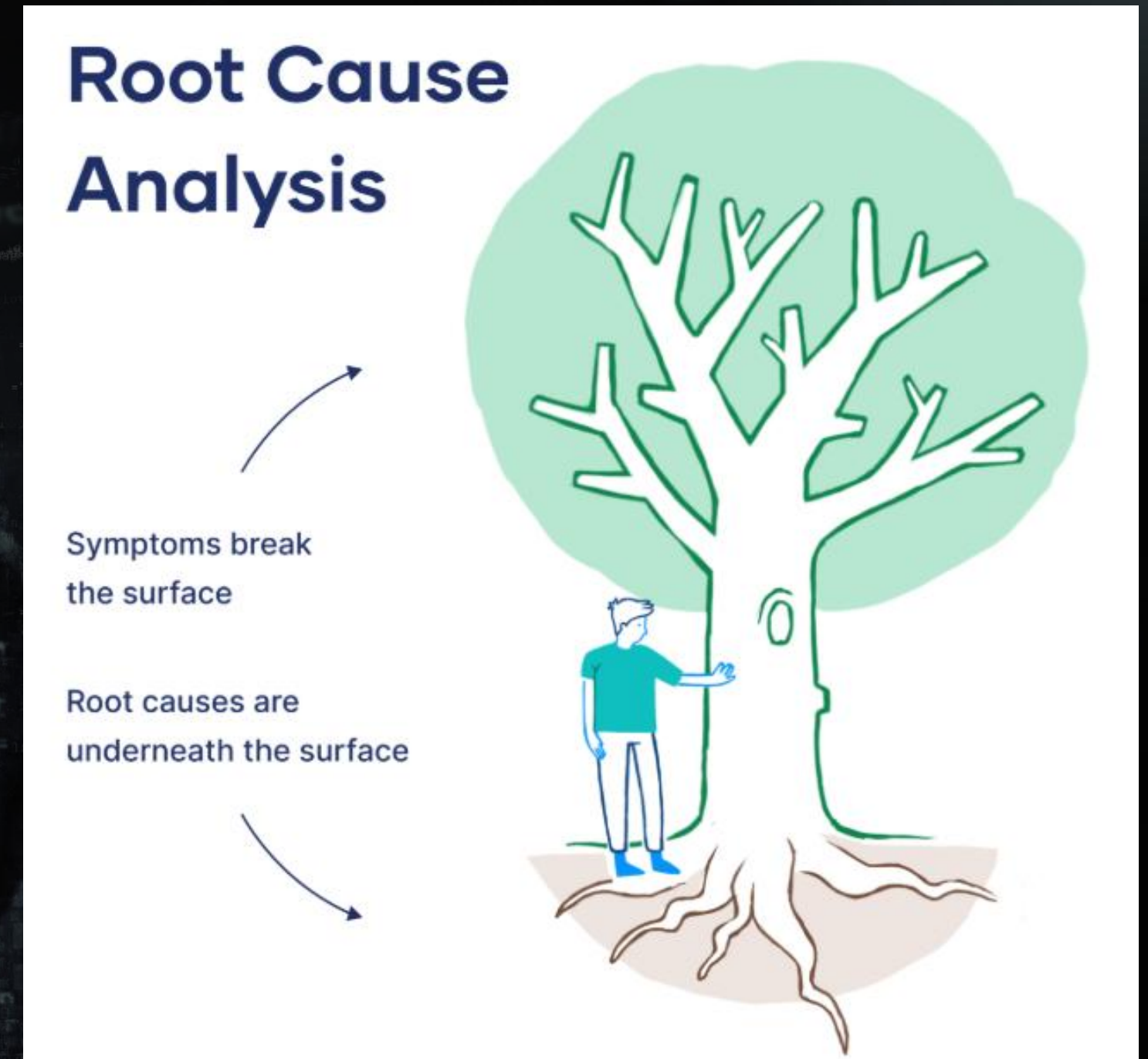
- Add an extra layer of security beyond just passwords
- Even if a password is compromised, MFA blocks unauthorized access
- Recommended for all admin and remote access accounts



7:ROOT CAUSE ANALYSIS (RCA)

1.Summary of Findings

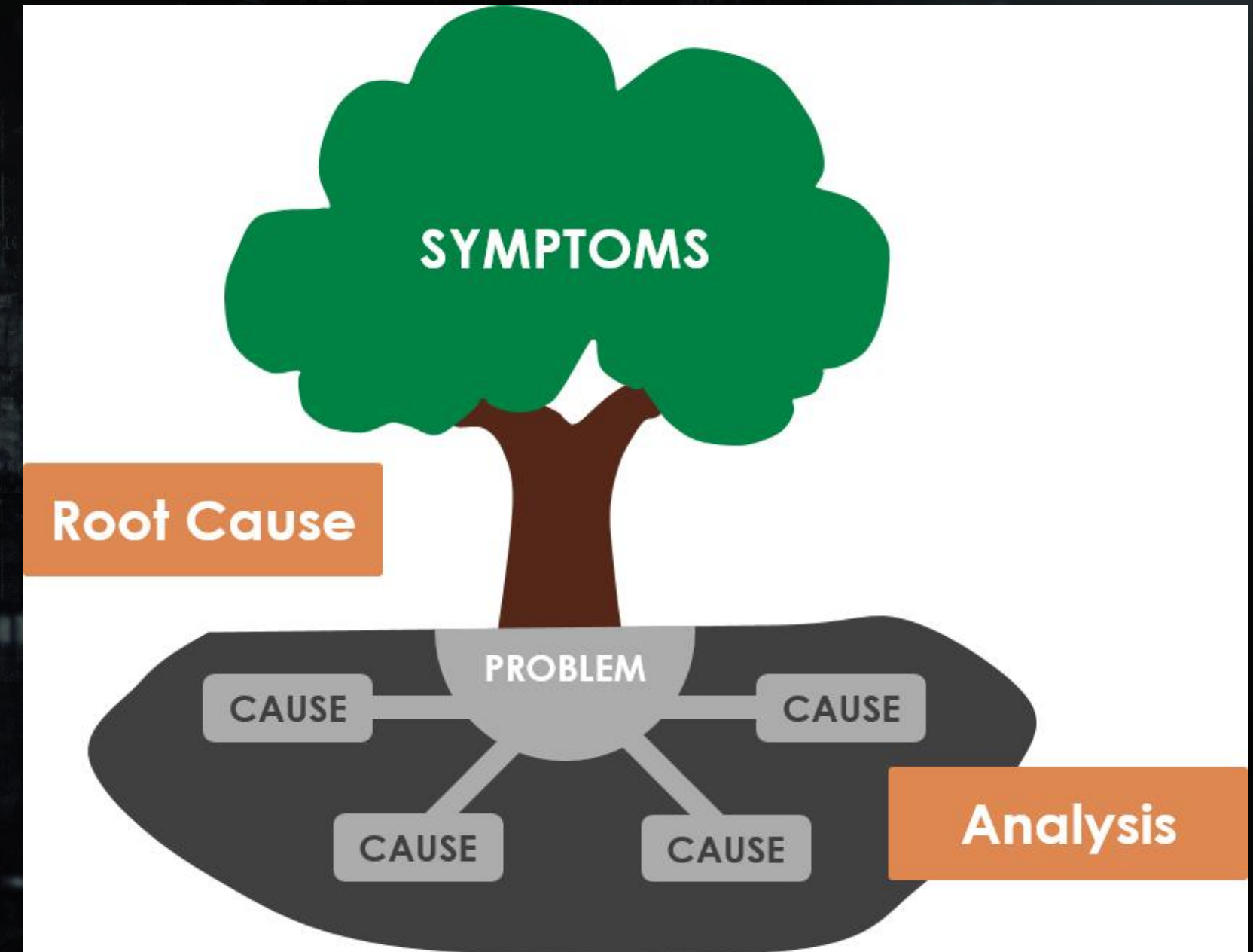
- Multiple failed login attempts (Event ID 4625) were recorded from a single IP
- Followed by a successful login (Event ID 4624) — indicating a likely brute-force attack
- The activity was detected using Windows Event Viewer Security logs
- The attack pattern matched common brute-force behavior (rapid, repeated login failures)



7:ROOT CAUSE ANALYSIS (RCA)

2.Importance of Monitoring

- Regular log monitoring helps detect suspicious patterns early
- Enables proactive incident detection and response before damage occurs
- Ensures accountability and traceability for authentication events
- Critical for meeting compliance and cybersecurity best practices



8.RECOMMENDATIONS & CONCLUSION

Security Best Practices

- Enable and monitor audit logs for login events (success & failure)
- Implement account lockout policies to block brute-force attempts
- Enforce strong password policies with regular updates
- Deploy Multi-Factor Authentication (MFA) for all remote/admin accounts
- Conduct regular security reviews and log analysis



RECOMMENDATIONS



8.RECOMMENDATIONS & CONCLUSION

Key Takeaways

- Event Viewer is a powerful tool for detecting login anomalies
- Brute-force attacks can be identified through login pattern analysis
- Log monitoring plays a vital role in incident response and prevention
- Combining detection with proactive security controls strengthens system defense



CONCLUSION

THANK YOU

BY VAISHALI

ID- 28802

